

APT29 — Cozy Bear: Advanced Persistent Threat Analysis

Classification:	TLP:WHITE — Unrestricted Distribution
Report ID:	CTI-2024-APT29-0042
Date:	March 2024
Author:	Threat Intelligence Unit
Confidence:	High (85%)

1. Executive Summary

This report provides a comprehensive analysis of APT29, also known as Cozy Bear, Midnight Blizzard, and NOBELIUM — a sophisticated threat actor attributed to the Russian Foreign Intelligence Service (SVR). APT29 has been active since at least 2008 and primarily targets government entities, diplomatic organizations, think tanks, healthcare providers, and technology companies across NATO member states and allied nations.

Between October 2023 and February 2024, APT29 conducted a highly targeted spear-phishing campaign dubbed Operation PHANTOM BEAR, leveraging a new malware family called WINELOADER alongside their established toolkit including SUNBURST, TEARDROP, and RAINDROP. The campaign resulted in confirmed intrusions into at least seven European diplomatic missions.

2. Threat Actor Profile

2.1 Attribution

APT29 (also tracked as Cozy Bear, Midnight Blizzard, The Dukes, NOBELIUM, Dark Halo) is a nation-state threat actor assessed with high confidence to operate on behalf of the Russian Federal Security Service (FSB) and SVR. The group has been active since approximately 2008, demonstrating exceptional operational security and advanced technical capabilities.

Attribute	Value
Primary Name	APT29 / Cozy Bear
Aliases	Midnight Blizzard, NOBELIUM, The Dukes, Dark Halo, Iron Hemlock
Sponsoring Nation	Russian Federation
Sponsoring Agency	SVR (Foreign Intelligence Service) / FSB

Active Since	~2008
Motivation	Espionage, Intelligence Collection, Political Influence
Sophistication	Expert
Primary Targets	Government, Diplomatic, Defense, Healthcare, Tech Sectors

3. Campaign: Operation PHANTOM BEAR

Operation PHANTOM BEAR is a targeted espionage campaign active from October 2023 through February 2024. The campaign exploited geopolitical events surrounding the Russia-Ukraine conflict as lures, targeting diplomatic personnel with wine-tasting event invitations — a social engineering tactic consistent with prior APT29 operations.

3.1 Attack Timeline

Date	Activity
Oct 2023	Initial spear-phishing emails distributed to European embassies
Nov 2023	WINELOADER dropper deployed on compromised ambassador workstations
Dec 2023	Lateral movement observed; credential harvesting via MIMIKATZ
Jan 2024	TEARDROP second-stage payload delivered; data exfiltration initiated
Feb 2024	Campaign detected; C2 infrastructure rotated to new IP ranges

4. Malware Analysis

4.1 WINELOADER

WINELOADER is a newly identified modular backdoor attributed exclusively to APT29. It is delivered via a ZIP archive attached to spear-phishing emails. Upon execution, the dropper injects shellcode into legitimate Windows processes (sqlwriter.exe) using process hollowing techniques. WINELOADER communicates with its C2 using HTTPS over port 443, with traffic obfuscated using RC4 encryption and base64 encoding. The malware achieves persistence via Windows Registry Run keys.

Property	Value
Name	WINELOADER
Type	Backdoor / Dropper
MD5	a3f5c2b1d4e6789012345678abcdef01
SHA-256	e3b0c44298fc1c149afb4c8996fb92427ae41e4649b934ca495991b7852b855
File Size	284,672 bytes

File Type	PE32+ executable (DLL)
First Seen	October 14, 2023
C2 Protocol	HTTPS (port 443)
Encryption	RC4 + Base64
Persistence	HKCU\Software\Microsoft\Windows\CurrentVersion\Run
Injection Target	sqlwriter.exe (process hollowing)

4.2 TEARDROP

TEARDROP is a memory-only dropper used in the second stage of the infection chain. It reads a fake JPEG image file (favicon.jpg) to extract and decode an embedded payload. TEARDROP has been observed loading a customized Cobalt Strike beacon configured for malleable C2 communication. It does not write artifacts to disk, making forensic detection challenging. SHA-256: 7acf71afa895df5358b0ede2d71128634bfbbc0e2d9deccff5c5eaa25e6f5510.

4.3 SUNBURST (Historical Context)

SUNBURST, used in the 2020 SolarWinds supply chain attack (CVE-2020-10148), remains a hallmark of APT29 capabilities. Though not observed in Operation PHANTOM BEAR, infrastructure overlaps with domains registered during the SolarWinds campaign were identified, suggesting shared infrastructure reuse.

5. Tactics, Techniques, and Procedures (TTPs)

APT29 consistently employs a sophisticated kill chain that emphasizes stealth, persistence, and anti-forensic measures. The following MITRE ATT&CK; techniques were observed during Operation PHANTOM BEAR:

ATT&CK ID	Technique	Description
T1566.001	Spear-phishing Attachment	ZIP archives with malicious DLL via email
T1055.012	Process Hollowing	Injection into sqlwriter.exe
T1547.001	Registry Run Keys	Persistence via HKCU Run key
T1071.001	Web Protocols	HTTPS C2 communications on port 443
T1573.001	Symmetric Cryptography	RC4 encryption for C2 traffic
T1003.001	LSASS Memory	Credential dumping via Mimikatz
T1027	Obfuscated Files	Base64 encoded payloads
T1041	Exfiltration Over C2	Data exfil via existing HTTPS channel
T1078	Valid Accounts	Use of stolen credentials for lateral movement
T1195.002	Supply Chain Compromise	Historical: SolarWinds (2020)

6. Indicators of Compromise (IOCs)

6.1 Network Indicators

Type	Value	Context
IP Address	185.220.101.45	WINELOADER C2 Server
IP Address	91.108.4.200	TEARDROP C2 Server
IP Address	194.165.16.78	Phishing Infrastructure
Domain	update.microsoftonline-cdn.com	Fake Microsoft C2 domain
Domain	cdn-telemetry.azure-api.net	Typosquat C2 domain
Domain	oauth2.live-signin.com	Credential phishing site
URL	https://update.microsoftonline-cdn.com/api/v2/push	C2 endpoint
URL	https://cdn-telemetry.azure-api.net/favicon.jpg	TEARDROP payload URL

6.2 File Indicators

Type	Value	File Name
SHA-256	e3b0c44298fc1c149afb4c8996fb92427ae41e4649b934ca495991b7852b856	wine loader.dll
SHA-256	7acf71afa895df5358b0ede2d71128634bfbbc0e2d9deccff5c5eaa25e6f5510	teardrop.exe
SHA-256	aabbcc1234567890aabbcc1234567890aabbcc1234567890aabbcc1234567890	teardrop.zip
MD5	a3f5c2b1d4e6789012345678abcdef01	wine loader.dll
MD5	5f4dcc3b5aa765d61d8327deb882cf99	favicon.jpg

7. Infrastructure Analysis

APT29 relies on a distributed, resilient C2 infrastructure leveraging bulletproof hosting providers, compromised legitimate servers, and typosquatted domains mimicking trusted cloud service providers. Infrastructure registered under AS59796 (Serverius) and AS20473 (Vultr) was extensively used during Operation PHANTOM BEAR.

Autonomous System Numbers: AS59796 (Serverius Holding B.V., Netherlands), AS20473 (Choopa LLC / Vultr, United States). The threat actor rotated C2 IP addresses every 14-21 days and employed domain generation algorithms (DGA) as fallback communication channels.

8. Exploited Vulnerabilities

CVE ID	Product	Description	CVSS
CVE-2023-23397	Microsoft Outlook	Zero-click privilege escalation; used for NTLM hash theft	9.8
CVE-2020-10148	SolarWinds Orion	Authentication bypass; used in supply chain attack (historical)	10.0
CVE-2019-19781	Citrix ADC/Gateway	Path traversal allowing arbitrary code execution	9.8

9. Recommendations & Mitigations

- 1. Block known C2 domains and IP ranges at perimeter firewall and DNS sinkholes.
- 2. Apply Microsoft patch MS23-0397 immediately to remediate CVE-2023-23397.
- 3. Enable multi-factor authentication (MFA) for all remote access and email services.
- 4. Deploy endpoint detection and response (EDR) with memory scanning capabilities.
- 5. Monitor for process hollowing techniques targeting sqlwriter.exe and svchost.exe.
- 6. Implement network segmentation to limit lateral movement from compromised endpoints.
- 7. Conduct user awareness training focused on spear-phishing recognition.
- 8. Hunt for WINELOADER artifacts: HKCU\Software\Microsoft\Windows\CurrentVersion\Run.

This report is classified TLP:WHITE. Recipients may share without restriction. For questions contact: cti-team@threatintel.example.com